

purdue-l1-basic-controllers brief

Purdue Basic Controllers (L1) — Cross-Vendor Threat & Detection Brief

Scope: Purdue Level 1 — the controllers that execute the physical process loop: chassis PLCs, compact PLCs, RTUs, protective relays, drives, and DCS process controllers. Roles in scope: chassis PLCs (Rockwell ControlLogix/GuardLogix 1756, Siemens S7-1500/400, Schneider Quantum/Premium), compact PLCs (Rockwell CompactLogix/Micro800, Siemens S7-1200/300, Schneider M340/M580, Honeywell ControlEdge UOC/PLC), DCS process controllers (Honeywell Experion C300/C200E), RTUs (Honeywell ControlEdge 2020, Schneider Momentum), protective relays/IEDs (SEL 300/351/387/400/421/451/487/700/751, Schneider Sepam 20/40/60/80), and variable-frequency drives (Rockwell PowerFlex 525/527/753/755, Siemens SINAMICS — research-only). Source briefs that contributed: [Eaton brief](#) (Group D bare-metal UPS MCU — L0/L1-adjacent, included for completeness), [SEL brief](#) (Groups C+D, research only), [Siemens brief](#) (Group D SIMATIC PLCs, research only), [Honeywell brief](#) (Groups A+B, research only — extraction pending), [Schneider brief](#) (Group A + Sepam in Group E, research only), [Rockwell brief](#) (Groups A, B, C, F, research only). Honest scope caveat: most L1 device firmware across all six vendors is **research-only** in the source briefs — CVE/CVSS/advisory IDs are preserved verbatim, but binary-level verification against extracted firmware has not occurred for any L1 controller except Eaton's UPS MCU `.sta` family.

Architecture grouping (organized by ROLE within this layer, not by vendor)

Class (role)	Products (cross-vendor)	Stack	Catalog depth
A. Chassis PLC	Rockwell ControlLogix 1756-L8x (5580) / L7x (5570) + 1756-EN2T/EN2TR/EN3TR/EN4TR comms; Siemens SIMATIC S7-1500, S7-400; Schneider Modicon Quantum, Premium	VxWorks 6.x/7.x (Logix), ADONIS RTOS (S7-1500), VxWorks (Quantum); CIP over EtherNet/IP (TCP/44818 + UDP/2222), S7comm/S7comm-Plus (TCP/102), UMAS over Modbus TCP/502, PROFINET	research only (see rockwell brief Group A , siemens brief Group D , schneider brief Group A)

Class (role)	Products (cross-vendor)	Stack	Catalog depth
B. Compact PLC	Rockwell CompactLogix 5380 (1769-L3xER) / 5370; Rockwell Micro800 (Micro820/830/850/870, 2080-LCxx); Siemens S7-1200, S7-300; Schneider Modicon M340, M580, Momentum; Honeywell ControlEdge UOC / ControlEdge 900 PLC	VxWorks on ARM/PPC (Logix), proprietary RTOS (Micro800), proprietary (S7-1200), VxWorks + Linux ePAC coprocessor (M580), embedded Linux + IEC-61131 runtime (UOC)	research only (see rockwell brief Groups B+C , siemens brief Group D , schneider brief Group A , honeywell brief Group B)
C. DCS process controller	Honeywell Experion C300, C200/E, ACE-T, Series-C I/O, FIM	VxWorks 6.x / pSOS on PowerPC + proprietary CEE control engine; Control Data Access (CDA) UDP/55555; FTE redundancy heartbeats; ControlNet/EtherNet-IP on Series-C	research only (see honeywell brief Group A)
D. RTU / remote outstation	Honeywell ControlEdge 2020 RTU; Schneider Modicon Momentum (Modbus); SEL-3530/3555 RTAC (concentrator role spanning L1/L2)	Embedded Linux + DNP3 (TCP/20000), Modbus TCP/502, IEC 60870-5-104 (TCP/2404), IEC 61131-3 logic	research only (see honeywell brief Group B , sel brief Group D)
E. Protective relay / IED	SEL-300/351/387/400/421/451/487/700/751; Schneider Sepam 20/40/60/80	Bare-metal embedded (proprietary RTOS), SEL Fast Message / SEL ASCII, IEC 61850 MMS (TCP/102) + GOOSE (Ethertype 0x88B8), DNP3 (TCP/20000), IEC 60870-5-104 (TCP/2404), Modbus RTU/TCP (Sepam)	research only (see sel brief Group C , schneider brief Group E)
F. Variable-frequency drive	Rockwell PowerFlex 525 / 527 / 753 / 755 / 755T / 6000T; Siemens SINAMICS (research)	bare-metal MCU + optional 20-COMM-E EtherNet/IP card, CIP, DPI peripheral bus, PROFINET	research only (see rockwell brief Group F , siemens brief Group D)
G. UPS internal MCU	Eaton 5P / 5PX / 5SC / 9PX / 9SX / 9PXM / 9170+ / Blade / Ferrups (Callisto chipset)	STM32 / Callisto MCU, flat <code>.sta</code> memory	6-96 hashes (see eaton brief Group D) —

Class (role)	Products (cross-vendor)	Stack	Catalog depth
(L0/L1-adjacent)		segments, no native network surface	flagged: UPS internal MCUs are not strictly Purdue L1 , included for completeness as they directly actuate power delivery

Group A — Chassis PLC

Direct attack surface: CIP over EtherNet/IP (TCP/44818 + implicit I/O UDP/2222), S7comm/S7comm-Plus (TCP/102), UMAS function code 0x5A tunneled over Modbus TCP/502, embedded HTTP/HTTPS web UI, SNMP on comms modules (EN2T/EN3TR/EN4TR), PROFINET DCP (L2, no auth), FTP/21 on legacy Quantum/M340, USB on L8x faceplate. Default factory state across vendors: CIP unauthenticated, web UI open, no CIP Security enforcement; software-override of mode switch when keyswitch in REM.

Confirmed CVEs across vendors:

CVE	CVSS	Vendor	Product	Vector
CVE-2024-6242	8.4	Rockwell	1756-EN4TR	CIP trusted-slot bypass, jump from any chassis slot to controller (Claroty "Bypassing the Trusted Slot")
CVE-2023-3596	7.5	Rockwell	1756-EN2T/EN2F/EN2TR/EN3TR/EN4TR	Malformed CIP packet → DoS of comms module (Claroty Team82, fixed in v12.001)
CVE-2022-38465	9.3	Siemens	SIMATIC S7-1200/1500	Hardcoded global private key → bypass protected communication & native-code load (Claroty Team82)

CVE	CVSS	Vendor	Product	Vector
CVE-2020-15782	8.1	Siemens	SIMATIC S7-1500	Memory-protection bypass → native code execution (Claroty)
CVE-2018-7841	9.8	Schneider	Modicon Quantum	UMAS auth bypass via web server
CVE-2021-22779	8.1	Schneider	M340/M580/Quantum/Momentum	UMAS reservation bypass ("ModiPwn", Claroty)
CVE-2022-45788	7.5	Schneider	Modicon M340/M580	UMAS undocumented Memory Write (Forescout OT:ICEFALL)
Siemens ProductCERT — S7-1500 CPU web-server DoS family (advisory index)	7.5	Siemens	S7-1500 CPU	Web server DoS

Top attack vector (MITRE ATT&CK ICS): [T0843 Program Download](#) over CIP/S7comm-Plus/UMAS — direct logic write to controller in RUN/REM. Volt Typhoon's 2024 US-infrastructure campaign (per CISA AA24-038A) included reconnaissance against ControlLogix on water and energy networks.

Group B — Compact PLC

Direct attack surface: Same CIP/EtherNet/IP stack as chassis PLCs (integrated Ethernet on the controller itself, no separate EN2T module on CompactLogix), S7comm on S7-1200/300, UMAS on M340/M580, OPC UA TCP/4840 on ControlEdge UOC, Modbus TCP/502, embedded HTTP/HTTPS UI, USB programming port (Micro800), SSH (later firmware), IEC-61131 download protocol over proprietary TCP. Entry-level Micro800 models have **no keyswitch** — mode change is purely software.

Confirmed CVEs across vendors:

CVE	CVSS	Vendor	Product	Vector
CVE-2021-22681	10.0	Rockwell	Logix family incl. CompactLogix 5370/5380	Hardcoded cryptographic key in Studio 5000 → remote auth bypass to controller (ICSA-21-056-03 , Claroty/Kaspersky/Otorio co-disclosure)

CVE	CVSS	Vendor	Product	Vector
CVE-2022-1161	7.7	Rockwell	CompactLogix 5380/5480, ControlLogix 5580	Stealthy logic injection (Studio 5000 view ≠ controller bytecode)
CVE-2023-2071	9.8	Rockwell	CompactLogix 5370 + EN2T-class comms	Crafted CIP packet → RCE on controller (ICSA-23-136-04)
CVE-2022-3157	7.5	Rockwell	Micro850/870	Crafted CIP → DoS major fault (ICSA-22-256-03)
CVE-2021-22779	8.1	Schneider	M340/M580	UMAS reservation bypass / session hijack from EWS
CVE-2020-7475	7.5	Schneider	M580	Hardcoded FTP credential
CVE-2022-38465	9.3	Siemens	S7-1200	Hardcoded global private key (shared with S7-1500)
ICSA-23-353-01 — ControlEdge UOC/VirtualUOC cluster	high	Honeywell	ControlEdge UOC / VirtualUOC	Improper authentication, privilege management, cleartext transmission on engineering link

Top attack vector (MITRE ATT&CK ICS): [T0833 Modify Control Logic](#) — CVE-2022-1161 "stealth" technique where engineer's online view diverges from running bytecode, paired with [T0858 Change Operating Mode](#) on Micro800-class controllers that lack a physical keyswitch.

Group C — DCS process controller (Honeywell Experion)

Direct attack surface: CDA (Control Data Access) UDP/55555, FTE redundancy heartbeats, embedded HTTP diag, Modbus TCP/502 (gateway role), OPC Classic DCOM, ControlNet/EtherNet-IP on Series-C I/O. C300/C200E controllers historically ship without firmware signing and accept boot images over CDA from any host trusted as a "supervisory" peer — the supervisory trust model is the bug.

Confirmed CVEs across vendors:

CVE / Advisory	CVSS	Vendor	Product	Vector
ICSA-23-061-02	Critical (CVSS 9.x)	Honeywell	Experion PKS / LX / PlantCruise	Multiple memory-corruption + auth-bypass bugs in CDA (ICEFALL "Crystallized Insecurity" cluster)

CVE / Advisory	CVSS	Vendor	Product	Vector
Claroty Team82 — ICEFALL "Crystallized Insecurity" (2023)	varied	Honeywell	Experion C300 family	9 ICEFALL-class flaws: unauth firmware update, unauth CDA writes, weak/no signing
Honeywell PSIRT — Experion C300 input-validation family	high	Honeywell	Experion PKS C300	Improper input validation in CDA → DoS / control disruption
Honeywell PSIRT — Experion hard-coded credential family	high	Honeywell	Experion PKS Server, ControlEdge	Hard-coded credentials in library → unauth RCE

Top attack vector (MITRE ATT&CK ICS): [T0857 System Firmware](#) via the unsigned CDA firmware-update path, chained with [T0836 Modify Parameter](#) to push tampered control logic to the C300 CEE.

Group D — RTU / remote outstation

Direct attack surface: OPC UA TCP/4840 (server), Modbus TCP/502, DNP3 (TCP/20000) on RTU variants, IEC 60870-5-104 (TCP/2404), embedded HTTPS config UI, SSH (later firmware), IEC-61131 download protocol over proprietary TCP. SEL-3530/3555 RTAC runs an embedded Linux ("RTAC OS") concentrating DNP3 master/slave, IEC 61850 client, Modbus, IEC 60870-5-104, with IEC 61131-3 logic.

Confirmed CVEs across vendors:

CVE / Advisory	CVSS	Vendor	Product	Vector
ICSA-23-194-02	high	SEL	SEL-3530/3555 RTAC family	Multiple weaknesses in RTAC firmware and management interfaces
ICSA-23-353-01 / CISA ControlEdge UOC advisories	high	Honeywell	ControlEdge UOC / VirtualUOC	Improper authentication, privilege management, cleartext transmission on engineering link
Honeywell PSIRT — ControlEdge VirtualUOC bulletin family	medium-high	Honeywell	ControlEdge VirtualUOC, UOC	Improper privilege management → controller config modification; cleartext sensitive info on engineering link
CVE-2021-22779	8.1	Schneider	Modicon Momentum	UMAS reservation bypass ("ModiPwn")

Top attack vector (MITRE ATT&CK ICS): [T0843 Program Download](#) — the IEC-61131 download path on UOC and the DNP3 control plane on Schneider/SEL outstations are the standard ICS persistence vectors.

Group E — Protective relay / IED

Direct attack surface: SEL Fast Message and SEL ASCII on serial / serial-over-TCP (the native control plane — read settings, write settings, trip/close breakers, reset targets); IEC 61850 MMS (TCP/102) and GOOSE (Ethertype 0x88B8) on Ethernet-enabled variants; DNP3 (TCP/20000); IEC 60870-5-104 (TCP/2404); Modbus RTU/TCP on Sepam; manufacture-time / default level-1/2/C passwords on SEL relays historically ([OTTER](#) , [TAIL](#) , [CLARKE](#)).

Confirmed CVEs across vendors:

CVE / Advisory	CVSS	Vendor	Product	Vector
CVE-2018-7790	7.5	Schneider	Sepam 20/40/60/80	Auth bypass on Modbus port
SEL Security Advisories index (research-only — no public CVE on relay firmware itself)	n/a	SEL	SEL-300/351/387/400/421/451/487/700/751	GOOSE injection on unauthenticated substation LANs (IEC 62351-6 GOOSE MAC rarely deployed); settings-group switch via Fast Message; default-credential history (INL/DOE red-team)

Top attack vector (MITRE ATT&CK ICS): [T0855 Unauthorized Command Message](#) via GOOSE injection or Fast Message from a compromised engineering workstation. CRASHOVERRIDE used precisely this pattern against Ukrenergo (different relay vendor, identical class of attack). Supporting: [T0836 Modify Parameter](#) — alter Sepam/SEL protective relay setpoints to defeat fault clearing.

Group F — Variable-frequency drive

Direct attack surface: Drive itself is bare-metal MCU; network exposure is through 20-COMM-E / embedded EtherNet/IP on PowerFlex, PROFINET on SINAMICS. CIP + DPI peripheral bus. No authentication on legacy 20-COMM-E.

Confirmed CVEs across vendors:

CVE / Advisory	CVSS	Vendor	Product	Vector
CVE-2022-1794	7.5	Rockwell	PowerFlex 755	Crafted CIP → drive fault / DoS (ICSA-22-153-02)
Rockwell PSIRT — PowerFlex 525 CIP fault family	high	Rockwell	PowerFlex 525	Malformed CIP → persistent fault
Siemens SINAMICS — no extraction-confirmed CVE; research-only via ProductCERT advisory index	n/a	Siemens	SINAMICS family	Research only

Top attack vector (MITRE ATT&CK ICS): [T0836 Modify Parameter](#) — direct CIP write of speed/accel/torque limits. A motor speed setpoint write outside commissioned bounds is a mechanical-damage attack (centrifuge / pump / conveyor).

Group G — UPS internal MCU (L0/L1-adjacent, Eaton .sta family)

Direct attack surface: No network attack surface on the UPS *itself* — .sta blocks are flat memory segments for Callisto-chipset MCUs. Reachable only via (a) serial/USB console (DB9/USB-B) — direct register access if attacker is local; (b) firmware tamper via `setUPS.exe` on the Windows admin host (the high-value path); (c) battery-management parameter abuse, particularly dangerous on Li-Ion products (9PX Lithium-Ion, 5P 1U-Lithium-Ion) — thermal-runaway risk if BMS protection thresholds are altered.

Confirmed CVEs across vendors: None against the UPS MCU itself; tampering path runs through the Windows admin host. See [eaton brief Group F](#) for [CVE-2025-59887](#) (8.6, UPS Companion DLL hijack) and [CVE-2020-6650](#) (UPS Companion <1.06 plaintext HTTP + `eval()`) as the foothold paths.

Top attack vector (MITRE ATT&CK ICS): [T0857 System Firmware](#) — compromise the Windows admin host that runs `setUPS.exe`, then push tampered firmware via the normal flash path. Flag: UPS internal MCUs are not strictly Purdue L1 controllers; included here because they directly actuate the physical power-delivery process and share the firmware-tamper-via-admin-host pattern with relays and drives.

Logging matrix (highest priority for this layer)

Top 8 — ordered by detection value per ingest dollar, cross-vendor:

#	Source	Event	What it catches	MITRE ATT&CK ICS
1	Network IDS (Suricata/Zeek)	CIP service codes 0x4B/0x4C/0x4D (program download), 0x52 (forward open from new source IP) on TCP/44818 + UDP/2222	Logic injection / Evil PLC on Logix family	T0843 Program Download
2	Network IDS	S7comm-Plus session from outside EWS VLAN to PLC TCP/102	Unauthorised SIMATIC PLC programming	T0843 Program Download
3	Network IDS	UMAS function 0x5A from non-EWS host on TCP/502	ModiPwn / UMAS auth-bypass against Modicon	T0855 Unauthorized Command Message
4	Network IDS	CIP class 0x6B (mode change) on TCP/44818 from non-engineering subnet; PROFINET DCP Set (IP/Name reassignment) from any non-engineer MAC	Software mode flip (Micro800, CompactLogix) + PROFINET hijack	T0858 Change Operating Mode + T0856 Spoof Reporting Message
5	Network IDS	GOOSE frames (Ethertype 0x88B8) sourced from non-relay MACs, or stNum jumps > expected; IEC 61850 MMS write services (TCP/102) from non-engineering hosts	GOOSE spoofing + IEC 61850 settings tamper on SEL/Sepam relays	T0855 Unauthorized Command Message
6	Network IDS	DNP3 function codes 5 (DirectOperate) / 6 (DirectOperateNoAck) crossing engineering→OT boundary; Modbus FC 5/6/15/16 on ControlEdge RTU / Series-C gateway	Breaker trip/close abuse + control-logic tamper	T0831 Manipulation of Control + T0833 Modify Control Logic
7	Network IDS	CDA UDP/55555 from outside Level-2 supervisory VLAN	ICEFALL-class lateral movement to Experion C300/C200E	T0843 Program Download
8	Controller native audit (Logix CIP 0xA0; Siemens S7-1500 diagnostic buffer; SEL relay SER;	Project download, key-switch position change, firmware updated, mode RUN↔STOP, settings-group switch, RST	Direct tamper attempts visible on the device itself	T0858 Change Operating Mode + T0857 System Firmware

#	Source	Event	What it catches	MITRE ATT&CK ICS
	Honeywell CDAEvent ; Experion System Event Journal)	TARGET outside maintenance windows		

Secondary:

- Firewall egress: any L1 controller originating outbound to non-RFC1918 is anomalous (Volt Typhoon callback path) — PLCs, RTUs, relays, drives should never browse the internet.
- OT-native process anomalies: PowerFlex speed setpoint write outside commissioned envelope; ControlLogix CPU load spike > 90% without project change (CVE-2023-3596 DoS precursor); GuardLogix safety-task watchdog trip without maintenance window; S7-1500 cycle-time drift > 10% on steady-state block; new OB/DB on a CPU outside change control; unexpected breaker open/close in relay SER outside maintenance windows; IEEE C37.118 synchrophasor stream gaps on PMU-capable relays.
- Vendor PSIRT feeds: Siemens ProductCERT publishes 2nd Tuesday monthly; Rockwell Trust Center, Schneider PSIRT, SEL Security Advisories, Honeywell PSIRT all RSS-subscribable for patch-window prioritization.

Cross-layer pivots

1. **L1 → L0 by writing setpoints to actuators (the physical-process outcome).** A successful CIP/S7/UMAS write to a PowerFlex drive's speed register, a Sepam relay's protection setpoint, or an Experion C300 CEE block produces the only outcome that matters: the physical process moves outside its commissioned envelope. This is the terminal step in [T0831 Manipulation of Control](#) and the goal of every L1 compromise.
2. **L1 → L3 via Evil PLC reverse attack on the engineering workstation.** Claroty Team82's "Evil PLC" class (documented against Rockwell Studio 5000, Schneider EcoStruxure Control Expert, and Siemens TIA Portal) weaponizes the controller itself: when the EWS uploads the project, a tampered PLC pushes payload to the engineer's host, pivoting L1 → L2/L3. See [rockwell brief Group E](#) + [schneider brief Group B](#).
3. **L1 PLC → adjacent L1 via shared PROFINET / EtherNet/IP segment.** Once code-exec exists on one chassis or compact PLC, the shared L2 industrial-Ethernet broadcast domain (PROFINET DCP, EtherNet/IP implicit I/O UDP/2222, CIP forward-open) gives equal-trust reach to every neighbouring PLC, RTU, drive, and relay on the same VLAN. The CVE-2024-6242 trusted-slot bypass on 1756-EN4TR is the canonical intra-chassis variant.
4. **L1 PLC → SIS is the TRITON pattern** (covered fully in the safety brief): once an L1 process controller is compromised and the SIS engineering link is reachable, the TriStation/SafeNet

wire-format weaknesses described in [schneider brief Group C](#) and [honeywell brief Group E](#) become the path to disabling the protection layer.

Sources

- [CISA ICS Advisory ICSA-21-056-03 — Logix Controllers \(CVE-2021-22681\)](#)
- [CISA ICS Advisory ICSA-23-136-04 — CompactLogix 5370 CVE-2023-2071](#)
- [CISA ICS Advisory ICSA-22-256-03 — Micro850/870](#)
- [CISA ICS Advisory ICSA-22-153-02 — PowerFlex 755](#)
- [CISA AA24-038A — Volt Typhoon US Critical Infrastructure](#)
- [CISA ICS Advisory ICSA-21-138-01 — Modicon UMAS / ModiPwn](#)
- [CISA ICS Advisory ICSA-22-228-04 — OT:ICEFALL Schneider](#)
- [CISA ICS Advisory ICSA-23-061-02 — Honeywell Experion PKS / LX / PlantCruise](#)
- [CISA ICS Advisory ICSA-23-194-02 — SEL Real-Time Automation Controller \(RTAC\)](#)
- [Siemens ProductCERT advisory index](#)
- [Rockwell Automation Trust Center — Security Advisories](#)
- [Schneider Electric PSIRT / Cybersecurity Support Portal](#)
- [SEL Security Advisories index](#)
- [Honeywell PSIRT / Security Notifications](#)
- [Claroty Team82 — Race to Native Code Execution on S7-1500 \(CVE-2020-15782 / CVE-2022-38465\)](#)
- [Claroty Team82 — Stealthy Rockwell PLC Hack \(CVE-2022-1161\)](#)
- [Claroty Team82 — Bypassing the Trusted Slot on 1756-EN4TR \(CVE-2024-6242\)](#)
- [Claroty Team82 — Evil PLC Attack: Weaponizing PLCs](#)
- [Claroty Team82 — ICEFALL Continues: Broken Trust, Broken Code \(Honeywell Experion\)](#)
- [Claroty Team82 — ModiPwn \(CVE-2021-22779\)](#)
- [Forescout — OT:ICEFALL research](#)
- [Forescout 2025 OT Threat Report](#)
- [Dragos — ICS Cybersecurity Year in Review \(CIP / Rockwell coverage\)](#)
- [INL — Cyber-Informed Engineering and substation red-team findings](#)
- [MITRE ATT&CK for ICS — T0843 Program Download](#)
- [MITRE ATT&CK for ICS — T0833 Modify Control Logic](#)
- [MITRE ATT&CK for ICS — T0836 Modify Parameter](#)
- [MITRE ATT&CK for ICS — T0855 Unauthorized Command Message](#)
- [MITRE ATT&CK for ICS — T0857 System Firmware](#)
- [MITRE ATT&CK for ICS — T0858 Change Operating Mode](#)
- [MITRE ATT&CK for ICS — T0831 Manipulation of Control](#)
- [CISA/NSA/FBI/ASD — Best Practices for Event Logging and Threat Detection \(2024\)](#)
- [IEC 62443 / Purdue reference — ISA-95 / ISA-99 layered architecture](#)
- [eaton brief — Group D bare-metal UPS MCU \(L0/L1-adjacent\)](#)

- [sel brief](#) — Groups C+D protective relays + RTAC (research only)
- [siemens brief](#) — Group D SIMATIC PLCs (research only)
- [honeywell brief](#) — Groups A+B Experion DCS + ControlEdge (research only)
- [schneider brief](#) — Group A Modicon + Group E Sepam (research only)
- [rockwell brief](#) — Groups A, B, C, F ControlLogix/CompactLogix/Micro800/PowerFlex (research only)